

Proyecto final

Despliegue de un honeypot



Introducción

Se plantea el despliegue y análisis de los datos recopilados por un honeypot. Se ha elegido para el desarrollo del proyecto el honeypot de código abierto tpot (<https://github.com/telekom-security/tpotce>) debido a su carácter amplio y general, pues esta herramienta permite el despliegue de treinta honeypots distintos, además de múltiples herramientas para el análisis de los datos recopilados de forma visual. Otra característica que incrementa el interés en esta propuesta es su popularidad, ya que se puede encontrar una gran cantidad de información que ayuda con su despliegue y solución de problemas.

Entre los distintos métodos que existen para la implementación de un honeypot (en hardware, en un VPS, en una VM etc.), se ha elegido la opción de instalarlo en una máquina virtual, pues he considerado que es la opción más segura y no requiere costos adicionales. Para añadir una capa más de seguridad y asegurar que los atacantes no puedan acceder a la red privada, se ha colocado el honeypot en la zona desmilitarizada (DMZ).

Debido a la cantidad de recursos limitados (de memoria) que se le han otorgado a la máquina virtual se ha decidido extraer los datos de un aproximado de hora y media de exposición.

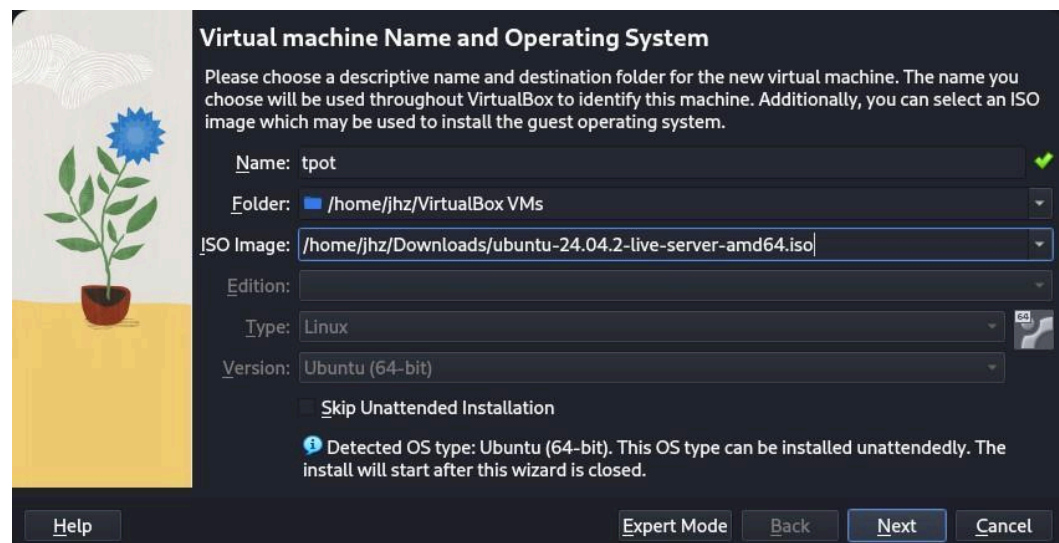
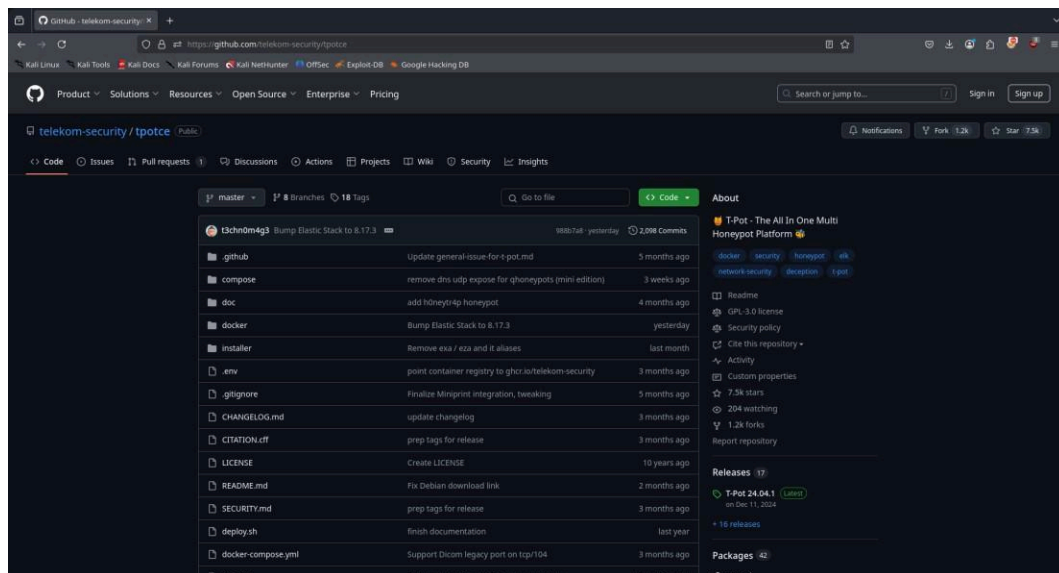
Para la recopilación de los datos se ha utilizado la herramienta Kibana (incluida en tpot) que muestra información interesante mediante gráficos de barras, líneas y circulares, además de permitir ver los CVE que tratan de explotar los atacantes. Por otro lado, durante media hora del tiempo de exposición se ha grabado la pantalla para obtener un video a tiempo real de los ataques mediante la herramienta Attack Map.

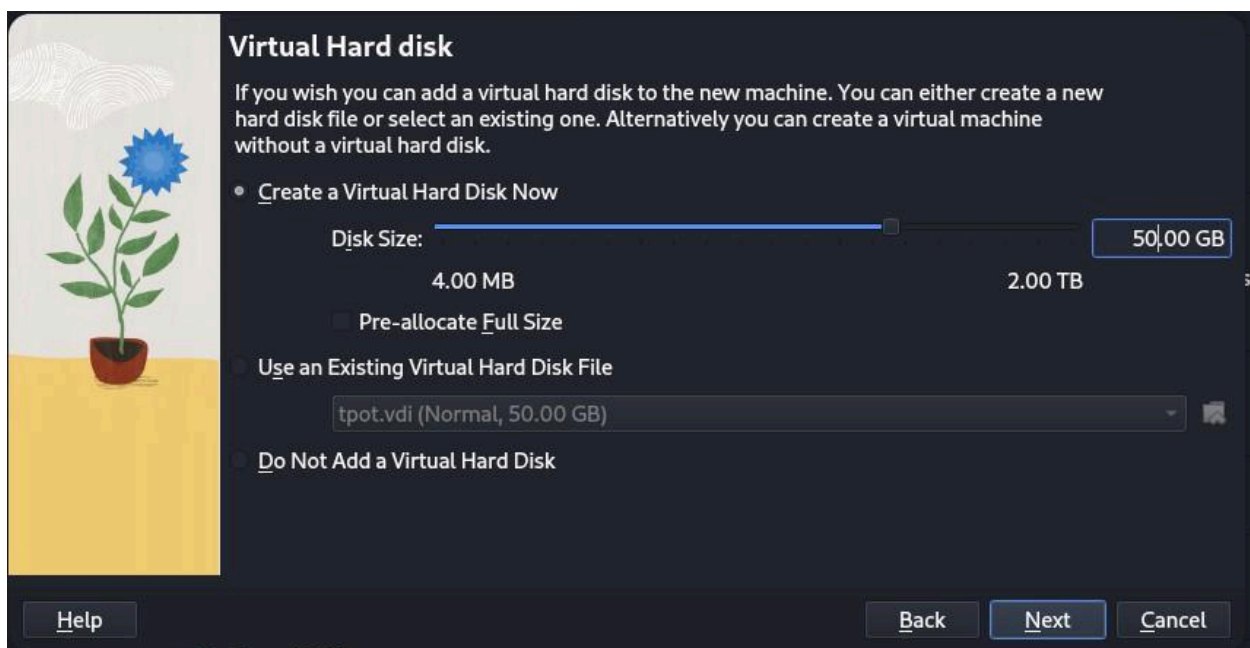
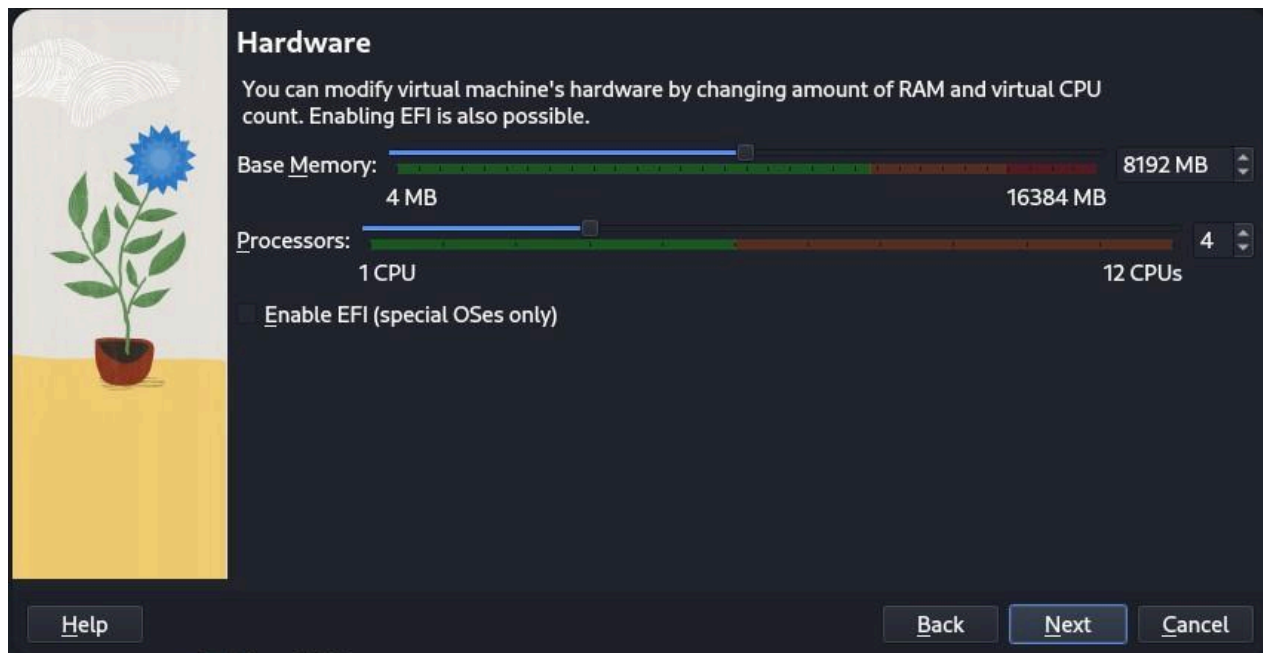
En este documento se detallará los pasos realizados para completar el proceso de desplegar el honeypot y se incluirá un análisis de forma superficial sobre los datos obtenidos. Además, se incluye un anexo con los distintos problemas que ocurrieron a la hora de realizar el despliegue (ver anexo).

Desarrollo (despliegue de tpot)

En primera instancia se intentó instalar el honeypot en un equipo de sobremesa y sistema

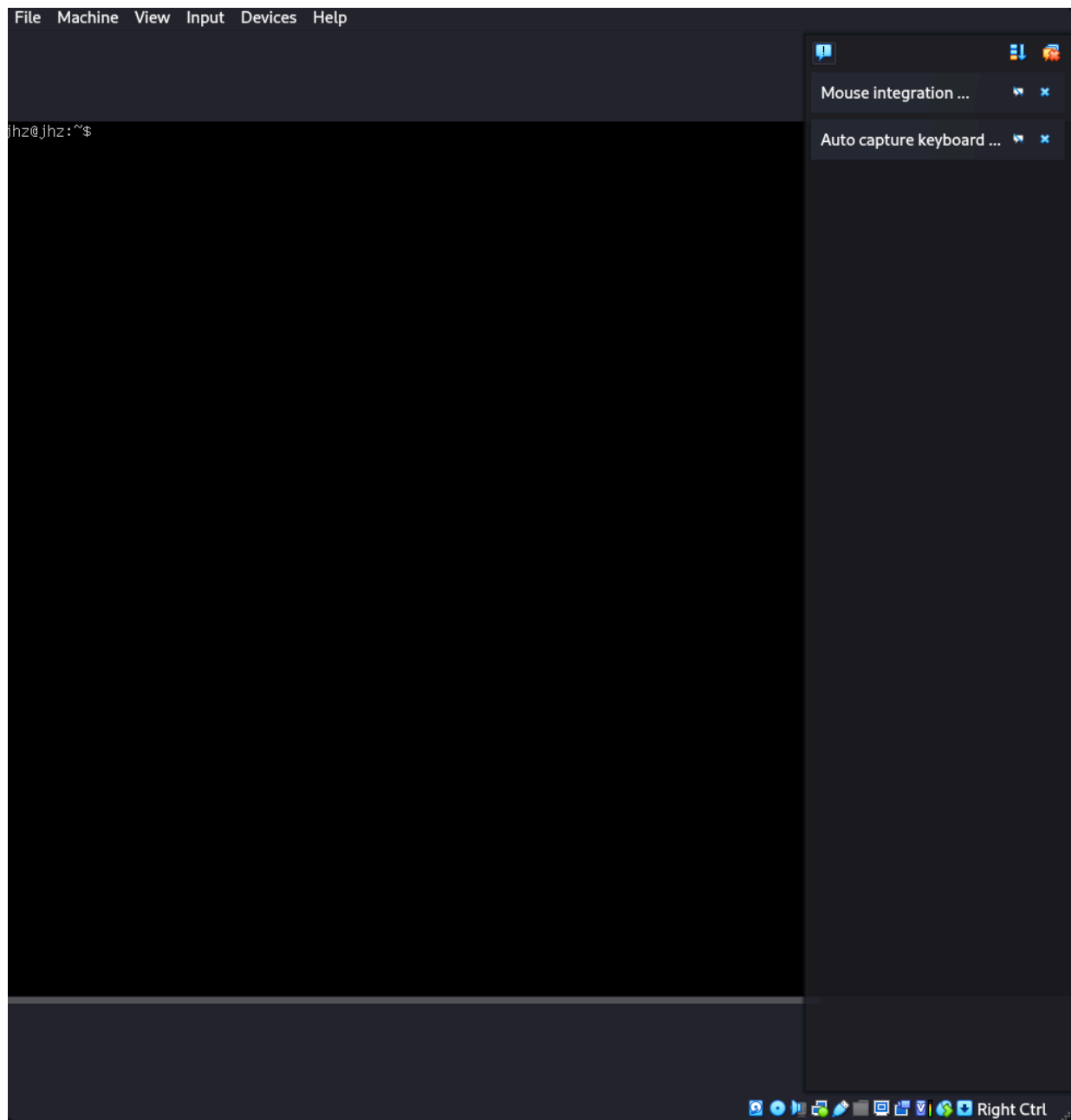
operativo Linux en el software de virtualbox. Para ellos, se comenzó descargando la imagen “.iso” del servidor Linux Ubuntu Live y configurando la maquina en virtualbox, donde se configuro con 8192 MB de memoria RAM, 4 núcleos y 50 GB de disco virtual.





Posteriormente, se procedió a la instalación de sistema operativo, durante esta, se usó el nombre de usuario “tpot”¹ y tras completarse, se realizó la instalación de la herramienta mediante una conexión ssh al servidor desde mi equipo². Entre las opciones

que permitía configurar tpot, se eligió la de (h)ive, que es la que más se adecuaba a los objetivos del proyecto.



```
jhz@jhz:~$ env bash -c "$(curl -sL https://github.com/telekom-security/tpotce/raw/master/install.sh)"
```

T-Pot Installer

```
### This script will now install T-Pot and all of its dependencies.
```

```
### Install? (y/n) y
```

```
### Please review for possible honeypot port conflicts.
### While SSH is taken care of, other services such as
### SMTP, HTTP, etc. might prevent T-Pot from starting.
```

Active Internet connections (only servers)

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	User	Inode	PID/Program name
tcp	0	0	0.0.0.0:64295	0.0.0.0:*	LISTEN	0	69397	19614/sshd: /usr/sb
tcp6	0	0	:::64295	:::*	LISTEN	0	69399	19614/sshd: /usr/sb
udp	0	0	192.168.42.100:68	0.0.0.0:*		998	73523	897/systemd-network

```
### Done. Please reboot and re-connect via SSH on tcp/64295.
```

```
ok: [127.0.0.1]
```

```
TASK [Disable ssh.socket unit (Ubuntu)] *****
ok: [127.0.0.1]
```

```
TASK [Remove ssh.socket.conf file (Ubuntu)] *****
ok: [127.0.0.1]
```

```
TASK [Change SSH Port to 64295 (AlmaLinux, Debian, Fedora, Raspbian, Rocky, Ubuntu)] *****
ok: [127.0.0.1]
```

```
TASK [Stop Resolved (Fedora, Ubuntu)] *****
changed: [127.0.0.1]
```

```
TASK [Modify DNSStubListener in resolved.conf (Fedora, Ubuntu)] *****
ok: [127.0.0.1]
```

```
PLAY [T-Pot - Restart services] *****
```

```
TASK [Gathering Facts] *****
*****
ok: [127.0.0.1]
```

```
TASK [Start Resolved (Fedora, Ubuntu)] *****
changed: [127.0.0.1]
```

```
TASK [Enable Docker Engine upon boot (All)] *****
changed: [127.0.0.1]
```

```
TASK [Restart SSH (All)] *****
changed: [127.0.0.1]
```

```
PLAY [T-Pot - Adjust group users, bashrc, clone / update T-Pot repository] *****
```

```
TASK [Gathering Facts] *****
ok: [127.0.0.1]
```

```
TASK [Check for non-root user id (All)] *****
ok: [127.0.0.1] => {
  "msg": "Detected user: 'jhz'"
}
```

```
TASK [Add aliases (All)] *****
ok: [127.0.0.1]
```

```
### Playbook was successful.
```

```
### Choose your T-Pot type:
### (H)ive - T-Pot Standard / HIVE installation.
###          Includes also everything you need for a distributed setup with sensors.
### (S)ensor - T-Pot Sensor installation.
###          Optimized for a distributed installation, without WebUI, Elasticsearch and Kibana.
### (L)LM - T-Pot LLM installation.
###          Uses LLM based honeypots Beelzebub & Galah.
###          Requires ollama (recommended) or ChatGPT subscription.
### M(l)ni - T-Pot Mini installation.
###          Run 30+ honeypots with just a couple of honeypot daemons.
### (M)obile - T-Pot Mobile installation.
###          Includes everything to run T-Pot Mobile (available separately).
### (T)arpit - T-Pot Tarpit installation.
###          Feed data endlessly to attackers, bots and scanners.
###          Also runs a Denial of Service Honeypot (ddospot).
```

```
### Install Type? (h/s/l/i/m/t) h
### Install Type? (h/s/l/i/m/t) h
```

```
### Installing T-Pot Standard / HIVE.
```

```
### T-Pot User Configuration ...
```

```
### Enter your web user name: jhz
### Your username is: jhz
### Is this correct? (y/n) |
```



```
### Now pulling images ...
[+] Pulling 117/121
✓ conpot_guardian_ast Skipped - Image is already being pulled by conpot_IEC104 0.0s
✓ conpot_kamstrup_382 Skipped - Image is already being pulled by conpot_IEC104 0.0s
✓ tanner_redis Skipped - Image is already being pulled by map_redis 0.0s
✓ map_data Skipped - Image is already being pulled by map_web 0.0s
✓ conpot_ipmi Skipped - Image is already being pulled by conpot_IEC104 0.0s
✓ tanner Skipped - Image is already being pulled by tanner_api 0.0s
✓ snare Pulled 232.2s
✓ tptotinit Pulled 191.0s
✓ fatt Pulled 291.0s
✓ mailoney Pulled 262.2s
✓ medpot Pulled 235.4s
✓ spiderfoot Pulled 542.8s
✓ tanner_api Pulled 137.5s
✓ cowrie Pulled 249.1s
: elasticsearch [[:]] 323.3MB / 660.2MB Pulling 580.0s
✓ dionaea Pulled 325.1s
✓ honeytrap Pulled 385.4s
✓ sentrypeer Pulled 69.6s
✓ ciscoasa Pulled 160.2s
✓ p0f Pulled 44.6s
✓ ewsposter Pulled 425.6s
✓ honeymail Pulled 389.7s
✓ conpot_IEC104 Pulled 152.9s
✓ map_redis Pulled 392.2s
✓ miniprint Pulled 26.3s
✓ elasticpot Pulled 20.9s
✓ tanner_phpox Pulled 207.1s
✓ map_web Pulled 171.5s
✓ adbhoney Pulled 14.2s
✓ heralding Pulled 43.9s
✓ logstash Pulled 444.8s
✓ nginx Pulled 483.0s
: kibana [[:]] 120.8MB / 355.1MB Pulling 580.0s
✓ iphone Pulled 58.7s
✓ redishoneypot Pulled 209.3s
✓ h0neytr4p Pulled 270.0s
✓ dicompot Pulled 144.1s
✓ wordpot Pulled 302.3s
✓ suricata Pulled 192.7s
```

Tras completar la instalación, puesto que el honeypot está montado en una red local, es necesario abrir los puertos que usa la herramienta para que redirija el tráfico de internet a mi honeypot4. Se comprobó el correcto funcionamiento y despliegue en primera instancia con la herramienta web “canyouseeme.org” para comprobar que los puertos eran accesibles desde internet y posteriormente (tras unos minutos desde el despliegue) se utilizó la herramienta de “shodan.io” para comprobar que mi IP publica se encontraba dentro de su base de datos y era visible.

NAT

Port ForwardingPort Triggering**DMZ**ALGAddress MappingSessions

A client in the Demilitarized Zone (DMZ) is no longer behind the Zyxel Device and therefore can run any Internet applications such as video conferencing and Internet gaming without restrictions. This, however, may pose a security threat to the Zyxel Device.

Default Server Address

192.168.1.4

Note

Enter the IP address of the default server in the **Default Server Address** field, and click **Apply** to activate the DMZ host. Otherwise, clear the IP address in the **Default Server Address** field, and click **Apply** to deactivate the DMZ host.

CancelApply

NAT

Port Forwarding

Port Triggering

DMZ

ALG

Address Mapping

Sessions

Use **Port Forwarding** to forward incoming service requests from the Internet to the server(s) on your local network. Port forwarding is commonly used when you want to host online gaming, P2P file sharing, or other servers on your network.

Add New Rule

#	1	2	3	4	5
Status					
Service Name	honeypot	honeypot2	honeypot3	honeypot4	honeypot5
Originating IP					
WAN Interface	Default	Default	Default	Default	Default
Server IP Address	192.168.1.4	192.164.1.4	192.168.1.4	192.168.1.4	192.168.1.4
Start Port	21	102	389	1433	10001
End Port	80	161	1080	9200	11434
Translation Start Port	21	102	389	1433	10001
Translation End Port	80	161	1080	9200	11434
Protocol	ALL	ALL	ALL	ALL	ALL
Modify					

Shodan

Maps

Images

Monitor

Developer

More...

Explore

Pricing

Search

Login

Regular View

Raw Data

Timeline

OpenMapTiles Satellite

MapTiler

OpenStreetMap contribute

// TAGS: honeypot

// LAST SEEN: 2025-03-10

General Information

Hostnames

Domains

Country

City

Organization

ISP

ASN

Spain

Madrid

Global Telecommunication Service Provider

Open Ports

10021

11000

// 10021 / TCP

1848324437

2025-03-10T21:21:11.045156

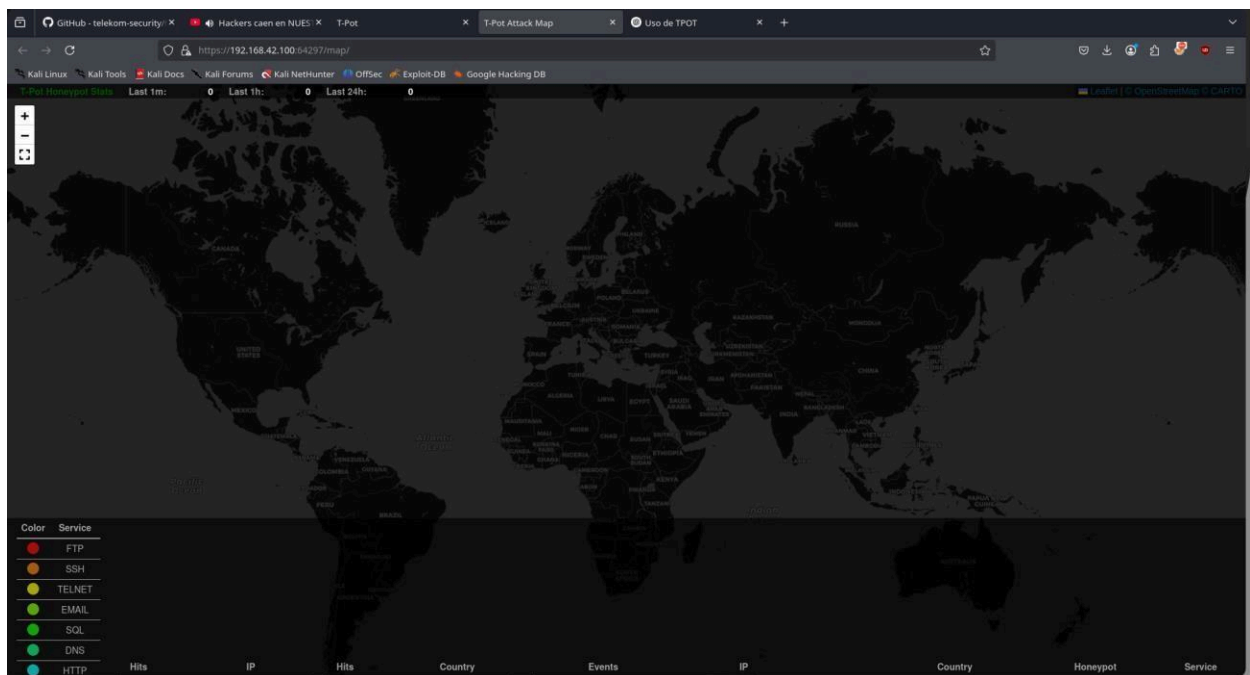
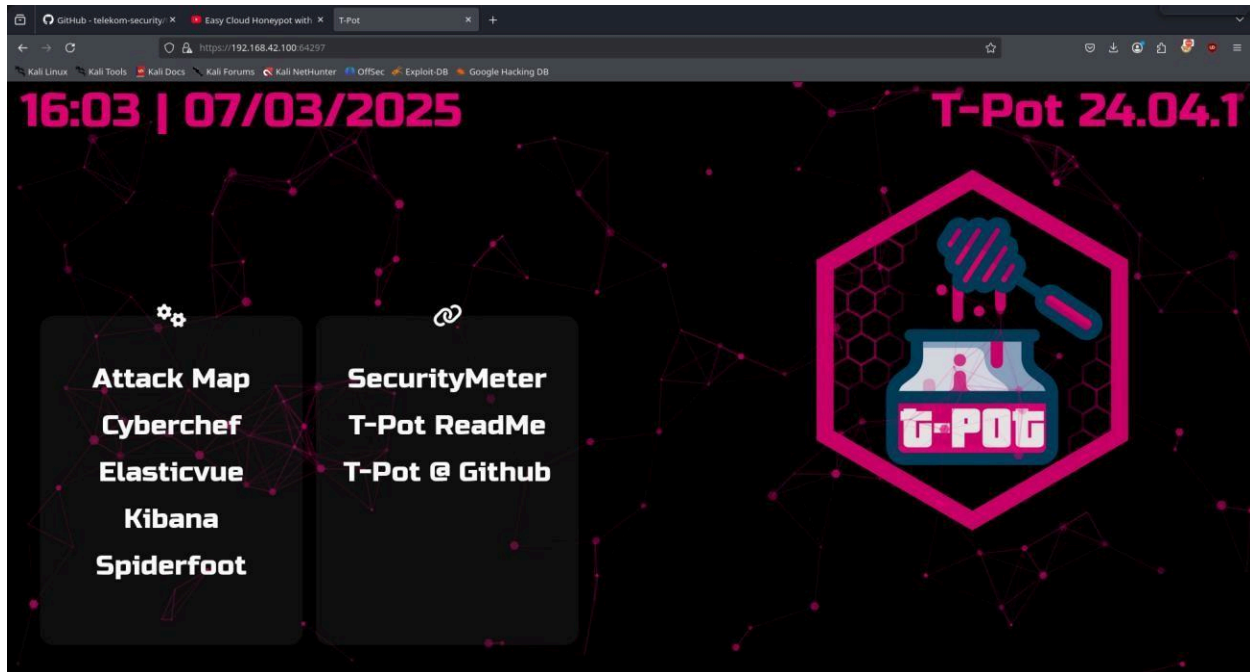
// 11000 / TCP

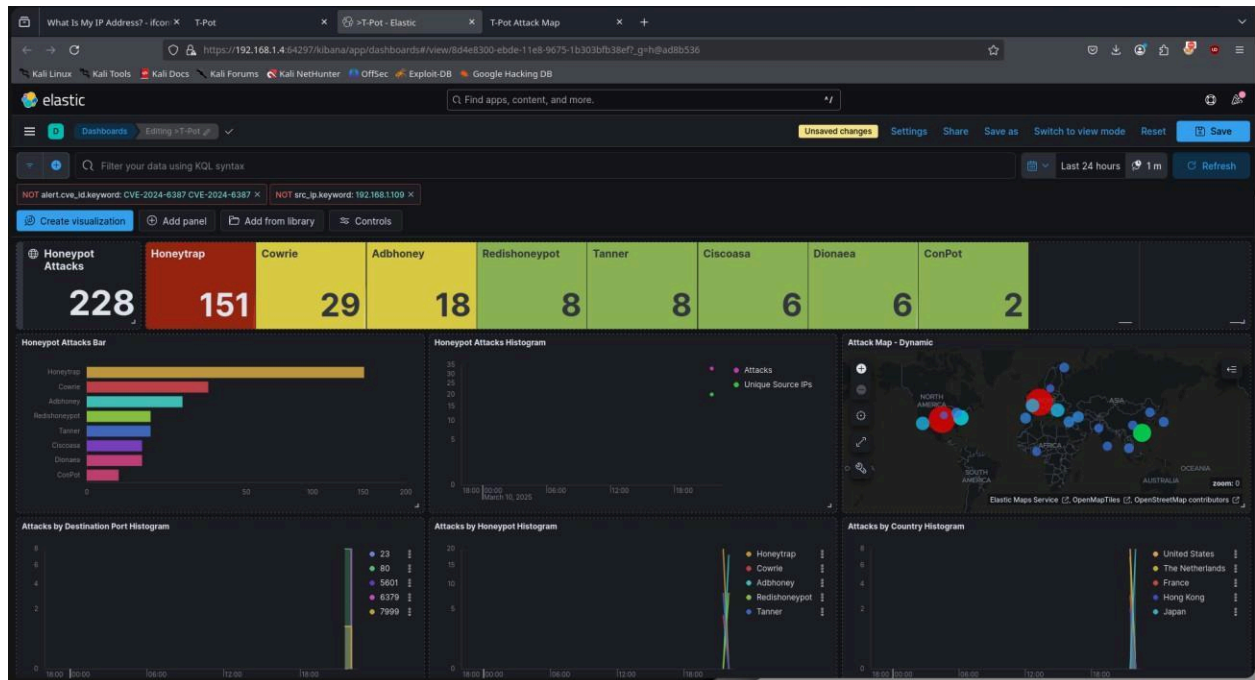
1869192275

2025-03-10T21:12:33.292824

\n

El proceso de despliegue de la herramienta estaba completo, se finalizará accediendo a la webUI por el puerto 64297 de mi servidor, y en este espacio se introducirá el usuario y la contraseña configurados en la instalación para poder acceder a los datos recopilados durante los diversos ataques.

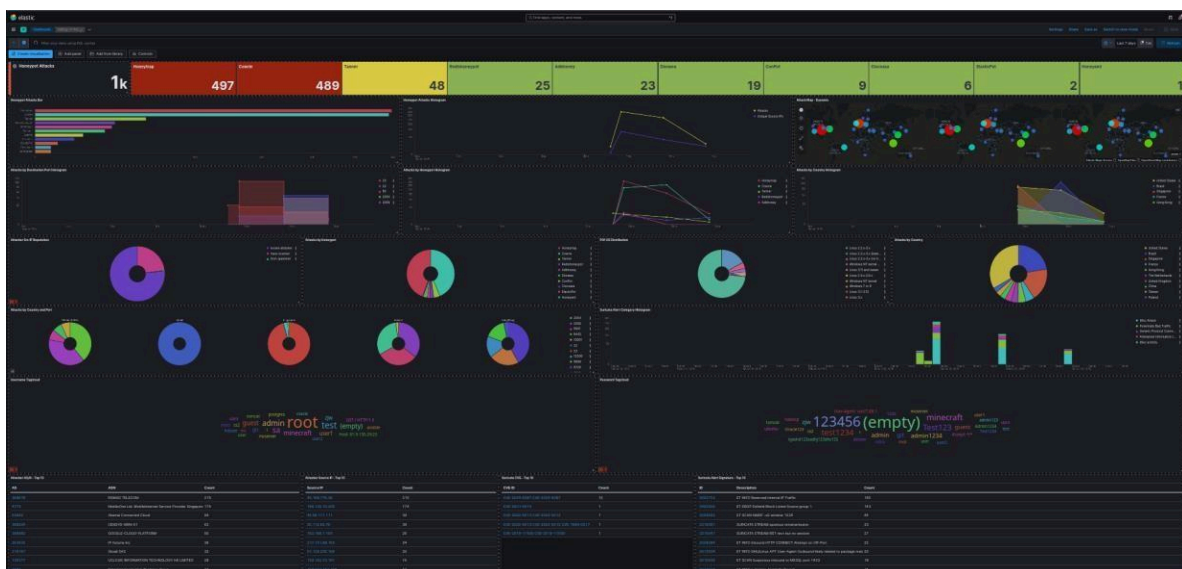




Análisis de los datos (Kibana)

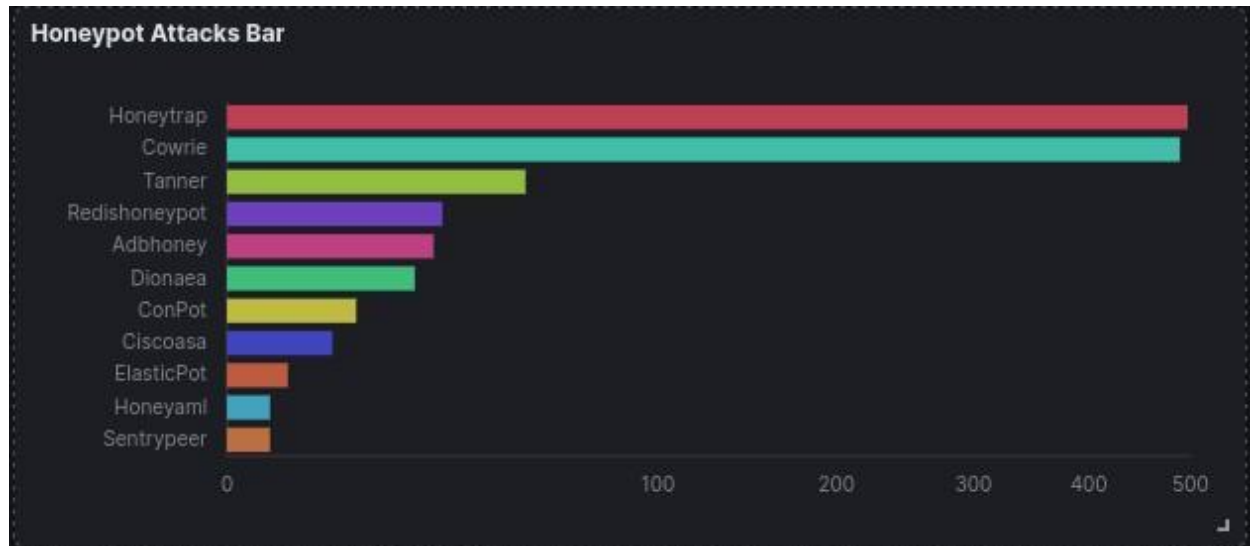
Los datos recopilados son resultantes de exponer el servicio a los ataques durante una hora y media, en total se han reportado más de mil ataques.

Vista general:

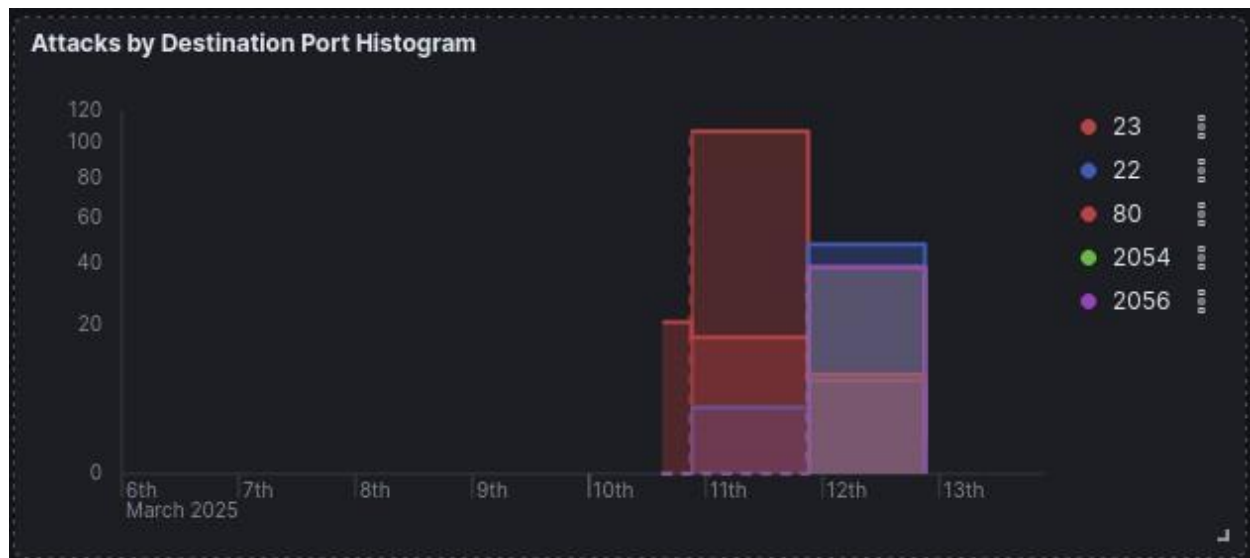


Veamos con más detalle alguno de los datos más interesantes. En primer lugar, podemos observar que los honeypots más atacados son con diferencia “Honeytrap” y “Cowrie”.

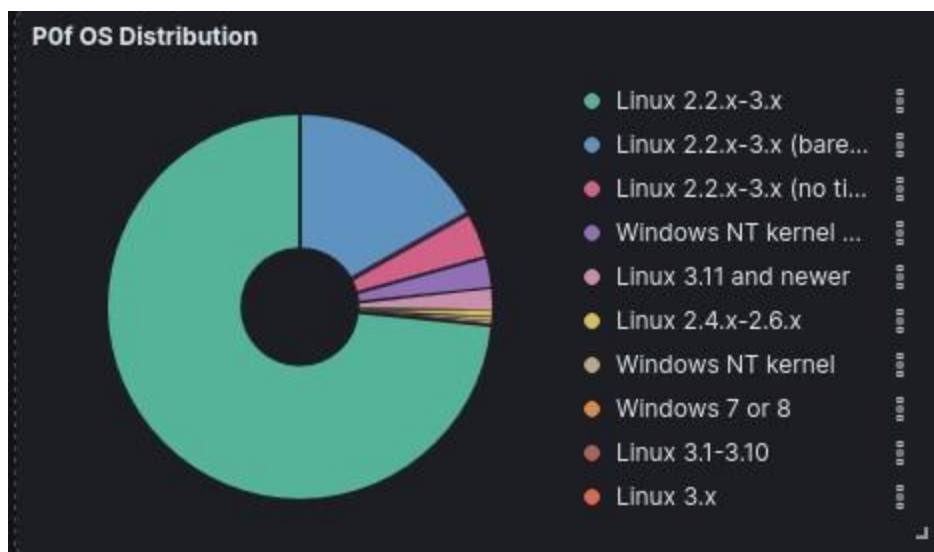
Por una parte, “Honeytrap” es así como tspot, un servicio de gestión de honeypots que combina distintos honeypots en uno solo, mientras que “Cowrie” es una herramienta interactiva de ssh y telnet, que registra los ataques por fuerza bruta.



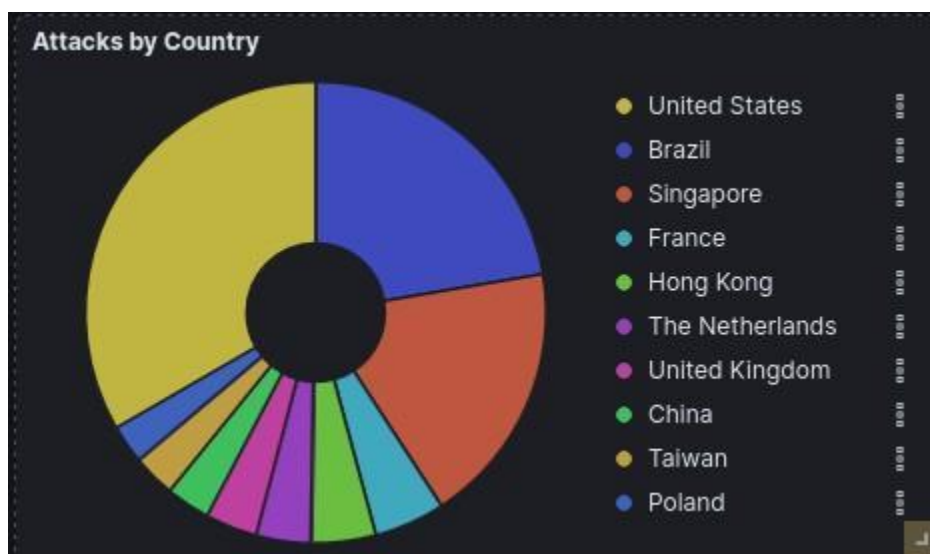
En segundo lugar, se muestra los puertos más atacados que respectivamente son los puertos: 23 (telnet), 22 (ssh), 80 (http), 2054 (weblogin) y 2056 (omnisky).



Posteriormente, se puede observar que la mayor parte de los ataques son realizados desde un sistema operativo Linux, seguido por Windows, destacando la ausencia de otros distintos.



Durante la investigación para la realización del proyecto, varias fuentes recalcan la importancia de la ubicación en la que se establezca el honeypot, pues el tráfico es distinto dependiendo del área geográfica desde donde se despliegue. En este caso, desde España, se observa (en este caso) que los ataques vienen en gran medida de países occidentales como los Estados Unidos y Europa, aunque se observa también la presencia de países del sureste asiático.



También, resulta interesante las credenciales que tratan de explotar los atacantes, destacando el uso de usuarios o contraseñas comunes como “root”, “admin”, “guest”, “123456”, “test1234”, “admin1234” y la combinación “sa” (System Admin) y “(empty)”,

que es usual encontrarla en el servicio de Microsoft SQL Server. Por otro lado, es apreciable también intentos de HTTP header injection y ataques de fuerza bruta.



Por último, podemos ver en algunos casos los CVE de las vulnerabilidades que los atacantes han intentado aprovechar. Por ejemplo, el CVE-2001-0414 se trata de un bufferoverflow que permite al atacante causar un ataque de denegación de servicio o una inyección de arbitraria de código.

Suricata CVE - Top 10	
CVE ID	Count
CVE-2024-6387 CVI	10
CVE-2001-0414	1
CVE-2002-0013 CVI	1
CVE-2002-0013 CVI	1
CVE-2019-11500 C\	1

Anexo problemas

- 1. El nombre de usuario “tpot” durante la instalación del honeypot crea conflictos.

2. Hasta ahora mi ordenador de sobremesa no contaba con una tarjeta wifi ni conexión ethernet por lo que accedía a internet mediante anclaje red (tethering), el problema radica en que no recibe la conexión directamente del enrutador por lo que es incapaz de conectarse a internet.
3. La “solución” al problema 2 fue la de realizar nuevamente el proceso de instalación, pero esta vez en un portátil. Al asumir de forma errónea los recursos que necesitaba la herramienta para desplegarse, hizo que nada más iniciar el servicio (`sudo systemctl start tpot`), el honeypot se cerrase unos treinta segundos más tarde. Finalmente, se continuó en el ordenador de sobremesa, pero esta vez se eligió comprar una tarjeta wifi (no era posible conectarse por ethernet).
4. Tras horas intentando abrir los puertos y comprobando si funcionaba con la herramienta “canyouseeme.org”, no se conseguía que mi honeypot fuese accesible desde internet. Tras una exhaustiva búsqueda, la solución radicó en llamar a mi IPS preguntando por el problema, la respuesta fue que la red estaba en una CG-NAT (Carrier Grade NAT), es decir, varios clientes de la compañía compartían una única IP pública y por lo tanto no se podían abrir los puertos. Sin embargo, tras eliminar las reglas de port forwarding al finalizar el proyecto, me di cuenta de que el honeypot seguía expuesto, investigando vi que simplemente posicionando el honeypot en la DMZ ya estaba expuesto a internet, pues todo el tráfico que no coincide con las reglas es redirigido a la DMZ (o eso tengo entendido).

Conclusión

Tras la realización de este proyecto se ha podido apreciar la inseguridad a la que un equipo indebidamente protegido está expuesto en el internet, para cuantizarlo se puede tomar como referencia una media de 11 ataques por minuto. Aunque no se trate de un resultado realista, pues se simulan una gran cantidad de equipos en estados ideales, nos permite percibir la magnitud de la importancia de la ciberseguridad en nuestros tiempos modernos.

Además, el despliegue del honeypot es un proyecto que ayuda a afianzar conocimientos principalmente sobre el funcionamiento redes (DMZ, port forwarding, firewall, servidores

etc.), sin despreciar tampoco las habilidades obtenidas en diversas herramientas de consola.